Persönliche Daten

IT-SICHERHEIT / SEMESTER 1 UND 2

1

AGENDA

01 PERSÖNLICHE DATEN

02 DSGVO IM ÜBERBLICK

03 SCHUTZ

04 ÜBUNG

tgm

2

01

Persönliche Daten

3

IT-SICHERHEIT / SEMESTER 1 UND 2

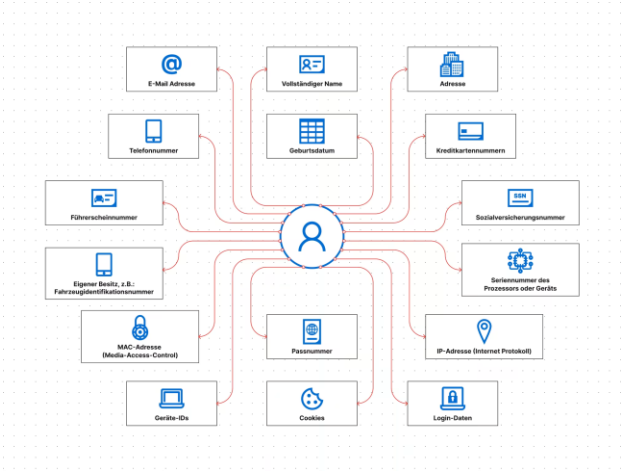
Was sind personenbezogene Daten?

4

IT-SICHERHEIT / SEMESTER 1 UND 2

Verknüpfte Informationen (auf Englisch: linked information)

- können auch als direkte Identifikatoren definiert werden.
- Direkte Identifikatoren sind **eindeutig einer Person zugeordnet** und können zur Identifizierung einer Person dienen. Ein einziger direkter Identifikator reicht normalerweise aus, um die Identität einer Person zu bestimmen.



[Quelle: https://piwikpro.de/blog/was-sind-pii-non-pii-und-personenbezogene-daten/ – letzter Abruf 29.10.2025]]

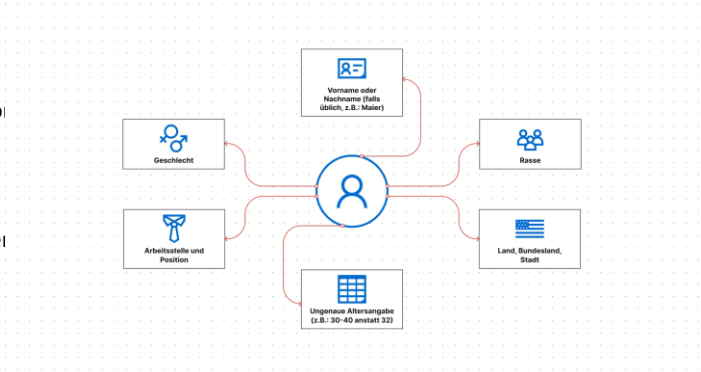
IT-SICHERHEIT / SEMESTER 1 UND 2

Verknüpfbare Informationen (auf Englisch: linkable information)

- **indirekte Identifikatoren** oder Quasi-Identifikatoren
- Sie lassen als alleinstehende Daten keine Perso erkennen.
- Sobald Sie sie aber mit einer zusätzlichen Information verknüpfen, ist es möglich, eine Person zu erkennen, zu tracken und aufzufinde

Beispiel:

- Recherchen zeigen, dass 87 % der US-Bürger allein aufgrund ihres Geschlechts, ihrer Postleitzahl und ihres Geburtsdatums identifiziert werden könnten.



[Quelle: https://piwikpro.de/blog/was-sind-pii-non-pii-und-personenbezogene-daten/ – letzter Abruf 29.10.2025]]

IT-SICHERHEIT / SEMESTER 1 UND 2

Personenbezogene Daten – Art. 4

„….alle Informationen, die sich auf eine identifizierte oder identifizierbare **natürliche Person** (im Folgenden „betroffene Person“) beziehen; als identifizierbar wird eine natürliche Person angesehen, die **direkt oder indirekt**, insbesondere mittels **Zuordnung zu einer Kennung** wie einem Namen, zu einer Kennnummer, zu Standortdaten, zu einer Online-Kennung oder zu einem oder mehreren besonderen Merkmalen identifiziert werden kann, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen **Identität dieser natürlichen Person sind**;“

tgm [Quelle: https://recht-neuwied.de/download/dsgvo.pptx – letzter Abruf 29.10.2025]]

IT-SICHERHEIT / SEMESTER 1 UND 2

Personenbezogene Daten

- Das Kriterium ist auch gegeben, wenn die Person über die Daten nur **identifizierbar** ist.
- Beispiel: Der Online-Shop kann über die Kundennummer die Person ohne weiteres identifizieren, auch, wenn ein Dritter dies nicht kann.
- Ähnliches gilt hinsichtlich der IP-Adresse in Bezug auf den Provider
- Es reicht also aus, wenn durch Zusatzwissen der Person ein Datum zugeordnet werden kann!

tgm [Quelle: https://recht-neuwied.de/download/dsgvo.pptx – letzter Abruf 29.10.2025]]

[Quelle: https://www.verbraucherzentrale.de/wissen/digitale-welt/datenschutz/ihre-daten-ihre-rechte-die-datenschutzgrundverordnung-dsgvo-25152 – letzter Abruf 17.3.2026]]

Konkrete Beispiele für personenbezogene Daten

- Name
- Adresse
- Geburtsdatum
- Mailadresse
- Kundennummer
- Vertragsbeziehungen
- Freundschaften (Facebook)
- Konsumverhalten
- Wahrscheinlichkeitsaussagen (Schufa)
- Arbeitszeiten
- Kontodaten
- IP-Adressen
- Cookies
- Etc.

[Quelle: https://webhoster.de/was-sind-personenbezogene-daten/ – letzter Abruf 29.10.2025]]

IT-SICHERHEIT / SEMESTER 1 UND 2

Was sind nicht personenbezogene Daten?

Der DSGVO nach sind nicht personenbezogene Daten jene Daten, **die keine Person erkennen lassen**. Das beste Beispiel sind anonyme Daten:

- Handelsregisternummern von Unternehmen
- E-Mail-Adressen von Vereinen, Organisationen, Gesellschaften oder Unternehmen
- Aggregierte Statistiken zur Nutzung von Produkten / Dienstleistungen
- Verallgemeinerte Daten, wie ein Altersbereich.
- Von staatlichen Stellen oder Gemeinden gesammelte Informationen wie Volkszählungsdaten oder Steuereinnahmen, die für öffentlich finanzierte Arbeiten erhoben werden.
- Aggregierte Statistiken zur Nutzung eines Produkts oder einer Dienstleistung.
- Teilweise oder vollständig maskierte IP-Adressen.

tgm [Quelle: https://webhoster.de/was-sind-personenbezogene-daten/ – letzter Abruf 29.10.2025]]

IT-SICHERHEIT / SEMESTER 1 UND 2

Besondere Kategorien personenbezogener Daten („sensible Daten“)

- Sensible Daten sind Informationen, mit denen eine Person **direkt identifiziert** werden kann und die im Falle einer Datenverletzung zu einem **Schaden** führen könnten.
- Sensible Daten sind **normalerweise nicht öffentlich zugänglich**.
- Viele Datenschutzgesetze verlangen von Unternehmen, dass sie diese **Daten verschlüsseln, den Zugriff darauf kontrollieren und andere Sicherheitsmaßnahmen** ergreifen.

Beispiele für sensible PII sind:

- rassische und ethnische Herkunft
- genetische Daten
- biometrische Daten
- politische Ansichten
- Gewerkschaftszugehörigkeit
- religiöse oder weltanschauliche Überzeugungen
- Gesundheitsdaten
- Daten zum Sexualleben oder der sexuellen Orientierung

tgm [Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

Personenbezogene Daten beinhalten ebenfalls Cookies und Login Informationen, mit dessen Hilfe ein Besucher wiedererkannt werden kann.

Erwägungsgrund 30 - *Natürlichen Personen werden unter* ***Umständen Online-Kennungen wie IP-Adressen und Cookie-Kennungen****, die sein Gerät oder Software-Anwendungen und -Tools oder Protokolle liefern, oder sonstige Kennungen wie Funkfrequenzkennzeichnungen zugeordnet. Dies kann Spuren hinterlassen, die insbesondere in Kombination mit eindeutigen Kennungen und anderen beim Server eingehenden Informationen dazu benutzt werden können, um Profile der natürlichen Personen zu erstellen und sie zu identifizieren.*

- **Die Definition von personenbezogenen Daten beinhaltet somit verschiedene Informationen:**
- Verlauf der Transaktionen
- IP-Adressen
- Browserverlauf
- Beiträge in sozialen Medien
- **Im Grunde sind das jegliche Informationen, die sich direkt oder indirekt auf eine einzelne oder identifizierbare Person beziehen.**

tgm [Quelle: https://piwikpro.de/blog/was-sind-pii-non-pii-und-personenbezogene-daten/– letzter Abruf 29.10.2025]]

[USA] Was sind persönlich identifizierbare Informationen (PII)?

- **Personal identifiable information**, auf Deutsch persönlich identifizierbare Informationen, ist vorwiegend ein **amerikanischer Begriff**.
- **US-Behörden und Nichtregierungsorganisationen (NRO)** verwenden ihn häufig. Da es in den USA jedoch kein übergeordnetes Gesetz über PII gibt, kann die rechtliche Definition des Begriffs von Gerichtsbarkeit zu Gerichtsbarkeit und von Staat zu Staat variieren.

Die gebräuchlichste Definition wird vom **Nationalen Institut für Standards und Technologie (NIST)** bereitgestellt:

PII sind ***alle Informationen über eine Person, die eine Behörde aufbewahrt****, einschließlich (1) aller Informationen, die zur* ***Unterscheidung oder Rückverfolgung der Identität einer Person*** *verwendet werden können, wie Name, Sozialversicherungsnummer, Geburtsdatum und -ort, Geburtsname der Mutter oder biometrische Aufzeichnungen; und (2)* ***alle anderen Informationen, die mit einer Person verknüpft sind oder verknüpft werden können****, wie medizinische, Bildungs-, Finanzinformationen und Informationen über den Beruf.*

tgm [Quelle: https://recht-neuwied.de/download/dsgvo.pptx – letzter Abruf 29.10.2025]]

02

DSGVO im Überblick Inhalt der Verordnung

15

IT-SICHERHEIT / SEMESTER 1 UND 2

DSGVO: Verarbeitung

sehr weit gefasst: **speichern, ändern, übermitteln, ordnen, anpassen, erheben, organisieren, verbreiten** … etc.

(teil)automatisiert = EDV = Regelfall

AUCH systematische Handdateien können darunter fallen

[Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

16

IT-SICHERHEIT / SEMESTER 1 UND 2

DSGVO: Grundprinzipien (Art. 5)

[Quelle: https://www.ibau.de/akademie/wissenswertes/dsgvo-kompakt-das-gilt-in-2020/ – letzter Abruf 17.3.2026]]

IT-SICHERHEIT / SEMESTER 1 UND 2

DSGVO: Rechtfertigungsgründe (Art. 6)

grundsätzlich jegliche Verarbeitung personenbezogener Daten verboten AUSSER mind. einer der nachfolgenden Rechtfertigungsgründe liegt vor:

- Einwilligung des Betroffenen (Art. 7)
- Vertragsverhältnis mit Betroffenem
- Rechtliche Verpflichtung des Verantwortlichen
- Schutz lebenswichtiger Interessen des Betroffenen / eines Anderen
- Wahrnehmung einer Aufgabe im öffentlichen Interesse / Ausübung öffentlicher Gewalt
- Berechtigtes Interesse des Verantwortlichen oder eines Dritten

[Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

DSGVO: Rechte der Betroffenen (Art. 12 – 22)

grundsätzlich jegliche Verarbeitung personenbezogener Daten verboten **AUSSER** mind. einer der nachfolgenden Rechtfertigungsgründe liegt vor:

- Informations- und Auskunftsrechte
- Recht auf Berichtigung
- Recht auf Löschung
- Recht auf Einschränkung der Verarbeitung
- Recht auf Datenübertragbarkeit
- Widerspruchsrecht

[Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

DSGVO: Sanktionen

Geldbußen bis zu 20 Mill € oder 4% des weltweit erzielten Jahresumsatzes bei

- Verstößen gegen DS-Grundsätze und Bedingungen für die Einwilligung
- Verstößen gegen die Rechte der betroffenen Person
- Verstößen gegen die Bestimmungen betreffend Übermittlung personenbezogener Daten in ein Drittland

Geldbußen bis zu 10 Mill € oder 2% des weltweit erzielten Jahresumsatzes bei

- Verstößen gegen die Pflichten der Verantwortlichen und der Auftragsverarbeiter
- Die Pflichten der Zertifizierungsstelle
- Verstößen gegen die Pflichten der Überwachungsstelle

Schadenersatz

[Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

03

Schutz

21

IT-SICHERHEIT / SEMESTER 1 UND 2

Wie man personenbezogene Daten schützt

Die Datenschutz-Grundverordnung enthält Leitlinien für den Schutz personenbezogener Daten. Zu den wichtigsten gehören:

Der Grundsatz der Rechtmäßigkeit

Am wichtigsten ist, dass die DSGVO einen klaren und gültigen Grund, sobald Sie personenbezogene Daten sammeln und verwenden wollen. Dieser Grund muss auf Notwendigkeit beruhen. Dies kann zum Beispiel die Erfüllung einer vertraglichen Verpflichtung oder die Erbringung einer Dienstleistung sein.

Der Grundsatz der Integrität und Vertraulichkeit

Eine der wichtigsten Möglichkeiten, Daten zu schützen, besteht darin, ihre Sicherheit zu gewährleisten, auch wenn die DSGVO nicht genau festlegt, wie diese Sicherheit in der Praxis aussehen soll. Die Wahl der Schutzmaßnahmen wird sich von Organisation zu Organisation unterscheiden. Schließlich ergreift ein Krankenhaus mit sensiblen Informationen über seine Patienten andere Maßnahmen als ein Blogger mit einem Newsletter.

tgm [Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

22

Wie man personenbezogene Daten schützt

Privacy by Design (Datenschutz durch Technikgestaltung)

Privacy by Design bedeutet die technischen und organisatorischen Maßnahmen in den ersten Planungsphasen der Datenverwaltung einzubringen.

Beispiele für diese Maßnahmen sind:

- Pseudonymisierung – Ersetzen oder Entfernen von Informationen innerhalb eines Datensatzes, die eine Identifikation einer betroffenen Person möglich machen. Verschlüsselung, Scrambling oder Masking gelten als gängige Methoden
- Anonymisierung – Entfernen personenbezogener Informationen aus einem Datensatz, die eine betroffene Person erkennen lassen.
- Überwachen der Datenverarbeitung.
- Hinzufügen von Datenschutz-Features und bereits verwendete verbessern.

Beachte, dass unter der DSGVO Pseudonymisierung keine genügende Anonymität bietet.

tgm [Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

Wie man personenbezogene Daten schützt

Privacy by Default (Datenschutz durch datenschutzfreundliche Voreinstellungen)

Privacy by Default basiert auf den Grundsätzen der Datenminimierung und Zweckbindung.

Gemäß dem Grundsatz der Datenminimierung sollten die Daten dem Zweck angemessen und erheblich sowie auf das für die Zwecke der Verarbeitung notwendige Maß beschränkt sein.

Zweckbindung bedeutet, dass Organisationen den Zweck der Datenverwaltung präzisieren, dokumentieren und betroffene Personen über die einzelnen Zwecke informieren, bevor sie Daten verwalten.

Organisationen, die nach diesen Grundsätzen handeln, erheben nur ein Minimum an Daten. Sie bewahren diese für so lange wie nur unbedingt nötig, um den gewünschten Zweck zu erfüllen.

tgm [Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]

Wie man personenbezogene Daten schützt

Datenschutz-Folgenabschätzung

Die DSGVO empfiehlt, eine Datenschutz-Folgenabschätzung (DSFA) durchzuführen, sobald ein mögliches Risiko vorliegt, dass betroffene Personen schädigen könnte. DSFAs helfen Organisationen, das Risiko eines Verstoßes zu verringern, indem sie mögliche Bedrohungen erkennen und mildern.

Erwägen Sie die Durchführung einer DSFA, wenn Sie:

- Neue Technologie einsetzen
- Sensible Daten in großem Umfang verarbeiten
- Systematisch öffentliche Plätze überwachen

tgm [Quelle: https://www.wko.at/datenschutz/eu-dsgvo-wichtige-begriffsbestimmungen#sensible_Daten – letzter Abruf 29.10.2025]]